

Assignment 04

Database Security Goals for the Mini Project

E/22/052 – K.H.D.M.Bimsara

1. Introduction to the Mini Project

The mini project is a Forensic Medico-Legal Case Management System (FMCMS), designed to digitise and manage the lifecycle of medico-legal cases handled jointly by hospitals, the police, judicial medical officers (JMOs), and the courts. The system is modelled directly on the real workflow and paper forms used in Sri Lankan forensic practice, including the Medicolegal Autopsy Notification Form, the Medico-Legal Examination Form (MLEF), the Post-Mortem Report (Health Form 1135), and the Court Certificate of Receipt of Medical Report.

The system tracks a case from the moment a death or injury is reported through clinical examination, autopsy, laboratory investigation of retained specimens, and finally the issuing of a medico-legal report to the court. Because the data captures identifiable personal, medical, and legal information about deceased and injured persons, security is not an optional add-on it is central to the system's legitimacy and to compliance with the law.

2. ER Diagram Reference and the 25 Core Tables

The ER diagram for the FMCMS is organised around five subsystems: (1) Case and Persons, (2) Institutions and Personnel, (3) Examination and Autopsy Records, (4) Injuries and Forensic Detail, and (5) System Administration. The Cases table is the central entity that every other subsystem links back to via case_id, which keeps the model a coherent star-like structure rather than a set of disconnected forms. The 25 main tables are summarised below.

Case & Persons

1. Cases	case_id (PK), case_type_id (FK), inquest_no, court_case_no, status, opened_date
2. Case_Types	case_type_id (PK), type_name (RTA, Homicide, Natural Death, Sudden Death, Assault)
3. Deceased_Persons	deceased_id (PK), case_id (FK), full_name, nic_no, age, sex, address, date_of_death, place_of_death
4. Injured_Persons	injured_id (PK), case_id (FK), full_name, nic_no, age, sex, address

Institutions & Personnel

5. Hospitals	hospital_id (PK), name, address, contact_no
6. Wards	ward_id (PK), hospital_id (FK), ward_name, ward_type
7. Police_Stations	station_id (PK), name, division, contact_no
8. Police_Officers	officer_id (PK), station_id (FK), name, rank, reg_no
9. Courts	court_id (PK), court_name, district, jurisdiction_level
10. Magistrates	magistrate_id (PK), court_id (FK), name, appointment_no
11. Medical_Officers	mo_id (PK), full_name, slmc_reg_no, qualification, designation, hospital_id (FK), user_id (FK)

Examination & Autopsy Records

12. Autopsy_Notifications	notification_id (PK), case_id (FK), hospital_id (FK), inquirer_name, magistrate_id (FK), pm_serial_no, date_of_death, cause_of_death_immediate, cause_of_death_antecedent, contributory_causes
13. PostMortem_Reports	pm_report_id (PK), notification_id (FK), mo_id (FK), inquest_no, exam_date, exam_place, verdict, cause_of_death_final
14. PostMortem_Findings	finding_id (PK), pm_report_id (FK), body_region, description, is_natural_opening, ordinal_no
15. MLEF_Forms	mlef_id (PK), case_id (FK), examinee_type (injured/deceased), mo_id (FK), police_officer_id (FK), reg_no, exam_datetime, category_of_hurt
16. Court_Certificates	cert_id (PK), case_id (FK), court_id (FK), pm_report_id (FK), trial_date, dispatch_date, registrar_signature_ref

Injuries & Forensic Detail

17. Injuries	injury_id (PK), case_id (FK), mlef_id (FK), body_site, nature, size_shape, severity_grievous_flag
18. Injury_Causes	cause_id (PK), injury_id (FK), weapon_type (blunt/sharp/firearm/burn/bite), description
19. Body_Diagram_Marks	mark_id (PK), case_id (FK), diagram_ref, coordinate_x, coordinate_y, annotation
20. Specimens	specimen_id (PK), case_id (FK), specimen_type, date_retained, purpose
21. Specimen_Investigations	investigation_id (PK), specimen_id (FK), lab_name, test_type (histology/serology/toxicology), result, result_date

System Administration

22. Users	user_id (PK), username, password_hash, salt, email, is_active, mfa_enabled
23. Roles	role_id (PK), role_name (Admin, JMO, Registrar, Police, Records Clerk, Auditor)
24. User_Roles	user_id (FK), role_id (FK), assigned_date
25. Permissions	permission_id (PK), role_id (FK), table_name, can_read, can_write, can_delete
26. Case_Documents	document_id (PK), case_id (FK), doc_type, file_path, uploaded_by (FK Users), upload_date, hash_checksum
27. Audit_Log	log_id (PK), user_id (FK), table_name, record_id, action (SELECT/INSERT/UPDATE/DELETE), timestamp, ip_address, old_value, new_value

3. Database Security Goals

3.1 Protect Sensitive Information

Several tables in the design hold data that is highly sensitive because it identifies real people and reveals private medical and legal facts about them. The clearest examples, taken directly from the source forms, are:

- Deceased_Persons and Injured_Persons full_name, nic_no, address, age, sex, and (in Autopsy_Notifications) cause_of_death_immediate / cause_of_death_antecedent. These fields correspond to the handwritten name, NIC, and cause-of-death entries on the Autopsy Notification Form, which are blacked out on the physical copies for exactly this reason.
- PostMortem_Findings and Injuries organ-by-organ findings, injury descriptions, and body_diagram_marks reveal intimate details of a person's body and death.
- Specimen_Investigations histological and serological results, which are medical test data comparable to lab results in any health record.
- Users password_hash and salt for every system account, and Case_Documents file_path and hash_checksum for scanned originals of signed forms.

Protection is implemented at three levels. First, encryption at rest for the Deceased_Persons, Injured_Persons, Autopsy_Notifications, PostMortem_Reports, and Specimen_Investigations tables, using column-level encryption for nic_no and cause-of-death fields so that even a raw database dump does not expose them in plaintext. Second, encryption in transit (TLS) between the application layer, the database server, and any client such as the records-entry terminal at a hospital ward. Third, password fields are never stored directly Users.password_hash uses a salted one-way hash (e.g., bcrypt/Argon2), consistent with the salt column shown in the schema, so plaintext passwords are unrecoverable even by administrators.

Views can also be used to control exposure: a "Case_Summary_View" can present case status and court dates to a registrar without exposing nic_no or full autopsy findings, mirroring the way the printed "Police Copy" of the MLEF omits the fuller clinical narrative retained in the hospital's Medical Officer's copy.

3.2 Prevent Unauthorized Access

The FMCMS defines distinct user roles that mirror the real signatories seen on the paper forms the Judicial Medical Officer who signs the autopsy notification and post-mortem report, the police officer who issues the MLEF, the court registrar who certifies receipt of the medical report, and administrative staff who register new cases. Role-based access control (RBAC) is implemented through the Roles, User_Roles, and Permissions tables, so that access is assigned to a role rather than hard-coded per user.

Role	Typical User	Read	Write	Delete	Scope
Administrator	System/DB administrator	All	All	All	Entire system incl. user accounts
Judicial Medical Officer (JMO)	Forensic pathologist / doctor	Own & assigned cases	Autopsy, PM report, findings, specimens	No	Cases they are assigned to
Registrar / Court Clerk	Court registry staff	Case status, certificates	Court_Certificates, Court_Hearings	No	Cases before their court
Police Officer	Investigating officer	MLEF, own case records	MLEF_Forms (own submissions)	No	Cases they filed
Records Clerk	Data entry staff	Assigned intake forms	Deceased/Injured_Persons, Case_Documents	No	Newly registered cases only
Auditor	Internal/external audit	Audit_Log, all tables (read-only)	No	No	Entire system, read-only

Access is enforced at the database layer (GRANT/REVOKE and row-level security tied to case_id and hospital_id/station_id) rather than relying solely on the application, so that a compromised application account cannot silently read every case in the country. A JMO, for example, can query PostMortem_Reports only for cases where mo_id matches their own Medical_Officers record, and a police officer can only write to MLEF_Forms for cases logged at their own Police_Stations row. Multi-factor authentication is required for the Administrator and JMO roles given the sensitivity of what they can access, matching the mfa_enabled flag on the Users table.

3.3 Maintain Accurate Data

Data accuracy is enforced structurally rather than left to manual double-checking, which mirrors the paper process's reliance on signatures and serial numbers to prevent tampering.

- Primary and foreign keys: every child table (e.g: PostMortem_Reports.notification_id, MLEF_Forms.case_id, Specimen_Investigations.specimen_id) is constrained by a foreign key back to its parent, so a post-mortem report cannot exist without a valid autopsy notification, and a specimen result cannot exist without a valid specimen record this mirrors how a real PM report cannot legally be filed without a prior notification.
- Unique constraints on natural identifiers such as Autopsy_Notifications.pm_serial_no, Court_Certificates.cert_id, and Users.username prevent duplicate case numbers, which is exactly the kind of numbering ("PM/2025/xxx", "KSK/2025/xxx") seen on the real notification and receipt forms.
- Check constraints and validation rules restrict Deceased_Persons.sex to a defined set, require date_of_death to not precede date_of_admission, and require age to be a non-negative integer.
- Referential integrity with ON DELETE RESTRICT on Cases prevents a case from being deleted while related autopsy, MLEF, or court records still reference it, avoiding orphaned forensic records.
- Application-level validation (e.g: NIC checksum format, mandatory examinee category on MLEF_Forms) supplements the database constraints, reducing transcription errors of the kind visible in the handwritten forms (e.g: ambiguous dates, ditto marks).

3.4 Ensure Continuous Availability

Because medico-legal reports are time-critical for court trial dates (as seen in the Certificate of Receipt of Medical Report, which records both the examination date and the report dispatch date), the system must remain available even during failures.

- Automated daily full backups plus continuous transaction-log (write-ahead log) backups, allowing point-in-time recovery to within minutes of a failure rather than losing a full day of case entries.
- A hot standby / replica database in a separate physical location, with automatic failover, so that a hospital or forensic department's server outage does not stop other departments from accessing case records.
- Scheduled maintenance windows outside working hours, with maintenance mode notifications rather than silent downtime, since Registrars and JMOs may need to retrieve case data for a court date at short notice.
- Regular, tested restore drills a backup that has never been restored is not a real backup verified against the Cases and PostMortem_Reports tables specifically, since these are the tables a magistrate's court will request in the event of a system incident.

3.5 Detect and Respond to Attacks

The Audit_Log table is the core detection mechanism: every INSERT, UPDATE, DELETE, and sensitive SELECT against tables such as Deceased_Persons, Autopsy_Notifications, and PostMortem_Reports is logged with user_id, action, timestamp, ip_address, and the old/new values, creating the digital equivalent of the signature-and-date trail required on every paper form ("Signature & Official Stamp ... Date").

- Failed-login monitoring and automatic account locking after a threshold of failed attempts on the Users table, to resist brute-force and credential-stuffing attacks.
- Anomaly alerts for example, a Records Clerk role account querying more than a defined number of Deceased_Persons rows in a short period, or any access attempt outside normal working hours, triggers an alert to the Administrator role.
- Database activity monitoring (DAM) at the network layer to detect SQL injection patterns or unusual query shapes against the case tables, independent of what the application layer logs.
- A documented incident-response procedure: suspected unauthorized access to Deceased_Persons or Specimen_Investigations triggers immediate credential revocation, a forced password reset for the affected role, and a review of the Audit_Log entries for that user_id before access is restored.

3.6 Comply with Legal and Regulatory Requirements

Because the system stores identifiable health and criminal-justice data about deceased and injured individuals, it must be designed around data-protection and evidentiary requirements, not just general good practice.

- Data minimisation and purpose limitation: fields such as nic_no and address are collected only because they are required for legal identification of the deceased/injured (as on the real MLEF and autopsy forms), and access to them is restricted to the roles that legally need them.
- Retention and disposal policy aligned with court and forensic record-keeping requirements case records are retained for the statutory period required for possible retrial or appeal, after which personal identifiers can be archived separately from clinical findings.
- Chain-of-custody integrity for Specimens and Specimen_Investigations, supported by hash_checksum on Case_Documents, so that a scanned autopsy report or lab result can be shown not to have been altered after the fact directly analogous to the physical requirement that specimens retained for histology/serology be traceable to the case they came from.
- Compliance with applicable data protection law (e.g: Sri Lanka's Personal Data Protection Act and hospital/court confidentiality rules) through documented data-sharing agreements between the hospital, police, and court entities

represented in the Hospitals, Police_Stations, and Courts tables, and through role-based disclosure controls so that, for example, a Registrar sees only the case status and certificate needed for the trial calendar, not the full autopsy findings.

- Auditability for regulatory inspection: the same Audit_Log used for attack detection also produces the access reports a data-protection or judicial oversight body could request to verify who accessed a given deceased person's record and why.

4. Recommendations for Improving Security

- Introduce field-level encryption specifically for nic_no and cause_of_death fields, rather than relying only on whole-database encryption at rest, so that even privileged database access does not casually expose these values in query results.
- Move from static role permissions toward attribute-based access control (ABAC) so that access can depend on case status (e.g., a case marked "closed/archived" becomes read-only even to the JMO who filed it).
- Add automated data-masking for training, testing, and reporting environments, so that development or statistics work never touches real names, NICs, or cause-of-death text.
- Formalise a security review cadence (e.g., quarterly access-review of the Permissions table) to catch role creep, such as a Records Clerk account that has accumulated write access it no longer needs.
- Extend the Audit_Log with tamper-evidence, such as periodic cryptographic hashing/chaining of log batches, so that even a compromised Administrator account cannot silently edit the audit trail.

5. Conclusion

Modelling the FMCMS directly on real medico-legal forms shows that database security goals are not abstract checklist items each one maps onto a concrete, already-existing control in the paper-based process: black-out redaction of NIC and names maps to encryption and masking; the requirement for a signing JMO or registrar maps to role-based access; serial numbers and case numbers map to primary/foreign-key integrity; and the requirement to keep a duplicate copy "under lock and key" maps to backup, replication, and audit logging. Implementing the six goals in the schema above gives the mini project a security posture that is at least as strong as, and considerably more consistent than, the paper system it digitises.